

Kriterien der Datenklassifizierung: Grundlagen, Schutzbedarf, Compliance und Business Continuity in der Informationssicherheit

Autor: Mevluet Polat

Zusammenfassung (Abstract)

In der gegenwärtigen digitalen Ära, in der Daten unbestritten als das wichtigste Kapital vieler Organisationen gelten, ist eine systematische Herangehensweise an die Informationssicherheit und das Datenmanagement unerlässlich. Dieser Artikel untersucht die fundamentalen Prinzipien der Datenklassifizierung und des Schutzbedarfs als Basis für robuste betriebliche Schutzmassnahmen. Ausgehend von den spezifischen Datenkategorien (von öffentlichen Daten bis hin zu streng reglementierten Personendaten) wird die Notwendigkeit der Ermittlung des spezifischen Schutzbedarfs beleuchtet. Anschliessend wird das klassische Modell der Informationssicherheit – bestehend aus Vertraulichkeit, Integrität und Verfügbarkeit (die sogenannte CIA-Triade) – detailliert analysiert. Diese klassische Betrachtung wird signifikant erweitert durch die Aspekte der System-Kritikalität (RTO, RPO) im Rahmen des Business Continuity Managements sowie durch die Anforderungen an Speichersysteme. Weiterhin beleuchtet der Text die zwingenden juristischen Rahmenbedingungen der Compliance. Abschliessend wird die Governance-Perspektive behandelt: Wie interne Richtlinien, rollenbasiertes Zugriffsmanagement, Cloud-Vorgaben und Sanktionen die Klassifizierung in der Praxis durchsetzen. Ziel dieses Artikels ist es, ein tiefgreifendes Verständnis dafür zu schaffen, wie die strukturierte Einordnung von Daten den Grundstein für eine resiliente, rechtskonforme und hochverfügbare IT-Architektur in Schweizer Unternehmen legt.

1. Einleitung: Die Notwendigkeit der systematischen Informationssicherheit

Die exponentielle Zunahme von Daten in modernen Geschäftsprozessen hat dazu geführt, dass Unternehmen vor der gewaltigen Herausforderung stehen, ihre Informationswerte nicht nur effektiv zu verwalten, sondern sie auch proaktiv abzusichern und rechtskonform zu verarbeiten. Der oft zitierte Satz "Daten sind das neue Öl" greift zu kurz, wenn man nicht berücksichtigt, dass rohes Öl erst durch einen strukturierten Raffinerieprozess nutzbar und sicher handhabbar wird. Ähnlich verhält es sich mit Unternehmensdaten: Nicht alle Daten

besitzen denselben inhärenten Wert für eine Organisation, und folglich benötigen nicht alle Daten das gleiche Mass an Schutz, dieselbe Systemverfügbarkeit oder denselben finanziellen Aufwand für deren Sicherung.

Eine undifferenzierte Sicherheitsstrategie, bei der versucht wird, alle Informationen gleichermassen mit den absolut höchsten Sicherheitsstandards (wie militärischer Verschlüsselung oder teuren Geo-Redundanzen) zu versehen, ist nicht nur ökonomisch hochgradig ineffizient, sondern in der betrieblichen Praxis zumeist schlichtweg unmöglich. Hier greift das fundamentale Konzept der Datenklassifizierung als Ausgangspunkt für jedes professionelle Information Security Management System (ISMS).

Der vorliegende Text analysiert die grundlegenden Kriterien der Datenklassifizierung anhand zentraler Aspekte: der eigentlichen Klassifizierung als strukturierte Einordnung mit ihren klaren Abstufungen, dem daraus resultierenden Schutzbedarf, den drei Kernzielen der Informationssicherheit (Vertraulichkeit, Integrität, Verfügbarkeit) sowie den zwingenden juristischen und betriebswirtschaftlichen Anforderungen in Bezug auf Compliance und Business Continuity. Diese Prinzipien bilden das unumstössliche Fundament, um sich in einer Welt voller Cyberbedrohungen und strenger Regulatorien (wie dem Schweizer Datenschutzgesetz) sicher bewegen zu können.

2. Klassifizierung: Die strukturierte Einordnung von Daten als Basis

Die Grundlage jeder massgeschneiderten und effektiven Sicherheitsarchitektur ist das tiefe Verständnis der eigenen Datenlandschaft. Der Leitsatz **"Die strukturierte Einordnung von Daten bildet die wichtige Grundlage für effektive betriebliche Schutzmassnahmen"** bringt dies prägnant auf den Punkt.

Klassifizierung bedeutet in diesem Kontext den formalen Prozess, bei dem Informationen nach ihrem Wert, ihrer Sensibilität und ihrer Kritikalität für das Unternehmen kategorisiert werden. Ohne eine solche Kategorisierung "tappt" ein Unternehmen sicherheitstechnisch im Dunkeln. IT-Sicherheitsverantwortliche wüssten nicht, wo die limitierten und teuren Ressourcen für Data Loss Prevention (DLP), Überwachung oder redundante Speicherung am besten eingesetzt werden sollten. Das primäre Ziel der Klassifizierung ist es, standardisierte Regeln (Policies) für den Lebenszyklus (Erstellung, Bearbeitung, Speicherung, Übertragung und Vernichtung) der jeweiligen Datenkategorien zu etablieren.

2.1. Die Abstufungen der Klassifizierungsmatrix im Detail

Eine typische, praxiserprobte Klassifizierungsmatrix baut auf fest definierten Kategorien auf. In der Schweizer Unternehmenslandschaft haben sich primär die folgenden fünf Kategorien etabliert, die den exakten Umgang mit den Informationen regeln:

1. Öffentliche-Daten

- **Definition:** Diese frei zugänglichen Informationen dürfen ohne jegliche Einschränkungen an externe Personen weitergegeben werden.
- **Erklärung:** Das Risiko bei der Offenlegung solcher Daten geht gegen null. Das Unternehmen beabsichtigt oder wünscht sogar, dass diese Informationen eine möglichst hohe Reichweite in der Öffentlichkeit erzielen. Ein Verlust der "Vertraulichkeit" ist hier logischerweise ausgeschlossen, da die Daten bereits für die Allgemeinheit bestimmt sind. Zu beachten ist bei öffentlichen Daten lediglich die Integrität (die Daten dürfen nicht von unbefugten Dritten verfälscht werden, um Rufschädigung zu vermeiden) und die Verfügbarkeit.
- **Beispiel:** Die wöchentliche Speisekarte der Betriebskantine, offizielle Pressemitteilungen auf der Unternehmenswebseite, Werbebroschüren für eine neue Produktlinie, oder der im Handelsregister publizierte und öffentlich einsehbare Jahresbericht einer Schweizer Aktiengesellschaft. Wenn ein potenzieller Kunde die Webseite aufruft, um sich über Dienstleistungen zu informieren, greift er auf Öffentliche-Daten zu.

2. Interne-Daten

- **Definition:** Solche Dokumente sind ausschliesslich für die eigenen Mitarbeitenden innerhalb des Unternehmens frei bestimmt.
- **Erklärung:** Diese Informationsklasse bildet den Standard (den sogenannten Default-Wert) in den meisten Unternehmungen. Die Daten sind für den reibungslosen, täglichen Betriebsablauf zwingend notwendig und grundsätzlich für jeden regulären Angestellten einsehbar. Sie haben jedoch ausserhalb der Firmenmauern absolut nichts zu suchen. Ein versehentliches Durchsickern (Data Leak) dieser Daten würde die Firma zwar in der Regel nicht in ihrer grundlegenden Existenz bedrohen, könnte aber zu peinlichen Situationen gegenüber Partnern oder zu einem leichten Reputationsschaden führen.
- **Beispiel:** Das firmeninterne Telefonbuch, Vorlagen für Spesenabrechnungen, allgemeine Richtlinien zur Nutzung von Firmenfahrzeugen, oder das Protokoll einer allgemeinen, abteilungsübergreifenden Betriebsversammlung. Diese Daten liegen typischerweise unverschlüsselt auf dem Firmen-Intranet (z.B. in einem SharePoint-Portal), auf das nur via verifiziertem Firmen-Login (SSO) zugegriffen werden kann.

3. Vertrauliche-Daten

- **Definition:** Nur ein klar definierter, eingeschränkter Personenkreis darf auf diese sensiblen Informationen direkt zugreifen.
- **Erklärung:** Bei dieser Kategorie greift das strikte "Need-to-Know"-Prinzip (Kenntnis nur bei Bedarf). Der Zugang wird nicht mehr pauschal allen Mitarbeitenden gewährt, sondern muss rollenbasiert und aktiv durch Berechtigungen (z. B. im Active Directory durch die IT-Administration nach Freigabe des Data Owners) erteilt werden. Die Offenlegung solcher Daten gegenüber Unbefugten – sei dies nun extern oder intern gegenüber Mitarbeitenden ohne explizite Berechtigung – kann zu signifikanten finanziellen Verlusten,

rechtlichen Konsequenzen oder einem grossen Imageverlust führen.

- **Beispiel:** Die detaillierten Bilanzen eines noch nicht abgeschlossenen Quartals, Budgets einzelner Abteilungen, strategische Marketingpläne vor der eigentlichen Markteinführung eines neuen Produkts, interne Revisionsberichte oder M&A-Pläne (Mergers and Acquisitions). Auf den Ordner mit dem strategischen Businessplan für das nächste Jahr dürfen beispielsweise nur die Geschäftsleitung und das erweiterte Strategieteam zugreifen.

4. Geheime-Daten

- **Definition:** Der unbefugte Zugriff auf diese Top-Geheimnisse könnte die Existenz der Firma stark gefährden.
- **Erklärung:** Dies ist die allerhöchste klassische Sicherheitsstufe für Unternehmensdaten. Der Schutzbedarf ist hier als absolut kritisch einzustufen. Ein Kompromittieren, Stehlen oder Veröffentlichen dieser Informationen führt zu katastrophalen Folgen, die das Unternehmen im schlimmsten Fall in den Konkurs treiben könnten. Die technischen und organisatorischen Massnahmen (TOMs) zur Sicherung dieser Daten sind extrem hoch, aufwendig und kostenintensiv (z. B. physisch getrennte Netzwerke, strikte Multi-Faktor-Authentifizierung mittels Hardware-Token, Safe-Räume).
- **Beispiel:** Der proprietäre Source Code (Quellcode) des Kernprodukts eines Software-Unternehmens, die exakte chemische Formel eines patentierten und hochprofitablen Medikaments eines Basler Pharmakonzerns oder die Algorithmen eines Hochfrequenz-Trading-Systems einer Bank. Wenn diese geheimen Daten an die Konkurrenz abfliessen, verliert das Unternehmen augenblicklich seinen massgeblichen Marktvorteil und somit seine gesamte Geschäftsgrundlage.

5. Personendaten

- **Definition:** Die Verarbeitung von persönlichen Kundeninformationen unterliegt stets den sehr strengen gesetzlichen schweizerischen Datenschutzrichtlinien.
- **Erklärung:** Diese Datenkategorie nimmt in der Klassifizierung eine Sonderstellung ein. Während die Kategorien 1 bis 4 primär den monetären und strategischen Wert der Daten für das *Unternehmen* widerspiegeln, schützt die Klassifizierung von Personendaten in erster Linie die informationelle Selbstbestimmung von *Individuen* (Kunden, Mitarbeitende, Partner). In der Schweiz reguliert das revidierte Datenschutzgesetz (revDSG) den Umgang mit solchen Daten strengstens. Ein Verstoß (z.B. ein Datenabfluss durch einen Hackerangriff) kann neben enormen Reputationsverlusten auch zu hohen Bussen durch den Eidgenössischen Datenschutz- und Öffentlichkeitsbeauftragten (EDÖB) führen. Besondere Vorsicht gilt bei "besonders schützenswerten Personendaten", die eine zusätzliche rechtliche Hürde darstellen.
- **Beispiel:** Eine CRM-Datenbank mit den vollständigen Namen, Wohnadressen, Geburtsdaten, AHV-Nummern und Bankverbindungen aller Kunden einer Schweizer Versicherung. Ebenso fallen darunter die Personalakten (HR-Dossiers) der eigenen

Mitarbeitenden, welche Krankheitszeugnisse, Lohndaten oder Leistungsbeurteilungen beinhalten. Elektronische Patientenakten (EPD) in einem Spital, die Diagnosen und Blutgruppen enthalten, sind ein Paradebeispiel für besonders schützenswerte Personendaten, die höchste Vertraulichkeit erfordern.

3. Schutzbedarf: Die Bewertung der Kritikalität

Direkt aus der zuvor definierten Klassifizierung leitet sich nahtlos der sogenannte Schutzbedarf ab. Im Grundlagentext heisst es präzise: **"Jede Information erhält einen spezifischen Schutzwert basierend auf der Kritikalität für das Unternehmen."** Die Schutzbedarfsfeststellung ist ein methodischer Kernprozess aus dem Risikomanagement. Hierbei wird fundiert bewertet, welcher tatsächliche Schaden eintreten würde, wenn die Schutzziele (Vertraulichkeit, Integrität, Verfügbarkeit) für bestimmte Daten verletzt würden.

Die Schadensszenarien, die im Rahmen einer solchen Analyse betrachtet werden, sind vielfältig und umfassen:

- **Finanzielle Einbussen:** Direkter Umsatzausfall, Vertragsstrafen (Penalties), Kosten für die Forensik nach einem Cyberangriff.
- **Reputationsverlust:** Imageschaden in der Öffentlichkeit, massiver Verlust von Kundenvertrauen und negativer Einfluss auf den Aktienkurs.
- **Rechtliche Konsequenzen:** Verstösse gegen Gesetze (DSG, DSGVO) und regulatorische Vorgaben (z.B. FINMA-Rundschreiben).
- **Personenschäden:** Die Beeinträchtigung der persönlichen Unversehrtheit (z.B. bei manipulierten medizinischen Daten).

Der Schutzbedarf wird in der Praxis klassischerweise in drei oder vier Stufen eingeteilt, wie beispielsweise *Normal*, *Hoch* und *Sehr hoch*. Ein *hoher* Schutzbedarf rechtfertigt und erzwingt zwingend kostenintensive und komplexe technische Sicherheitsmassnahmen. Ein *normaler* Schutzbedarf rechtfertigt hingegen lediglich Basis-Sicherheitsmassnahmen (Grundschutz), da die Kosten für den Schutz sonst den eigentlichen Wert der Information übersteigen würden – dies ist ein zentraler Grundsatz der Wirtschaftlichkeit in der IT-Sicherheit.

Ausführliches Beispiel zum Schutzbedarf:

Ein grosses Schweizer Kantonsspital verarbeitet täglich zehntausende von Datensätzen. Wir betrachten zwei spezifische Datentypen, um den stark divergierenden Schutzbedarf zu illustrieren:

- **Datentyp A (Dienstplan des Reinigungspersonals - Interne-Daten):** Fällt dieses IT-System aus (Verletzung der Verfügbarkeit) oder wird es leicht manipuliert (Verletzung der Integrität), entsteht eine kurze organisatorische Verwirrung am Morgen, die sich durch einige klärende Telefonate durch die Schichtleitung schnell beheben lässt. Der Schutzbedarf ist hier klar als **Normal** einzustufen. Basis-Backups und eine Standard-

Firewall sind ausreichend.

- **Datentyp B (Elektronische Patientenakten - Besonders schützenswerte Personendaten):**
Wenn diese Daten in die Hände unbefugter Dritter gelangen, liegt eine massive Verletzung der ärztlichen Schweigepflicht und des revDSG vor (Verletzung der Vertraulichkeit). Noch gravierender wird es, wenn diese Daten manipuliert werden: Löscht ein Angreifer beispielsweise eine Penicillin-Allergie im System aus der digitalen Akte (Verletzung der Integrität), kann dies für den Patienten bei einer bevorstehenden Notoperation tödliche Konsequenzen haben. Der potenziell resultierende Schaden ist immateriell, irreversibel und rechtlich verheerend für das gesamte Spital. Folglich ist der Schutzbedarf für diese Patientenakten als **Sehr hoch** zu deklarieren. Dementsprechend müssen strengste Netzwerksegmentierungen, Ende-zu-Ende-Verschlüsselungen und lückenlose Protokollierungen zwingend implementiert werden.

4. Die klassischen Säulen der IT-Sicherheit: Die CIA-Triade und ihre Erweiterungen

Die Einstufung der Datenkategorien (von Öffentlich bis Geheim) und die Ermittlung des jeweiligen Schutzbedarfs geschehen in der IT nicht im luftleeren Raum. Sie orientieren sich konzeptionell immer an drei essenziellen Zieldimensionen, die im internationalen Sprachgebrauch als **CIA-Triade** (Confidentiality, Integrity, Availability) bekannt sind.

4.1. Vertraulichkeit: Das Prinzip der autorisierten Zugänge

Vertraulichkeit (Confidentiality) ist oftmals das allererste Kriterium, an das Laien denken, wenn sie den Begriff "Informationssicherheit" hören. Der Basistext definiert: **"Dieses zentrale Kriterium bestimmt, wer überhaupt die Berechtigung besitzt, bestimmte Informationen zu lesen."** Dies ist insbesondere bei *Vertraulichen-Daten*, *Geheimen-Daten* und *Personendaten* der massgebliche Faktor.

Das absolute Kernkonzept der Vertraulichkeit ist das bereits erwähnte "Need-to-Know"-Prinzip. Es besagt, dass ein Mitarbeiter, ein externer Berater oder auch ein automatisiertes IT-System nur auf exakt jene Daten zugreifen darf, die für die Erfüllung einer sehr spezifischen Aufgabe zwingend erforderlich sind. Vertraulichkeit schützt sensible Informationen vor unbefugter Preisgabe, sei es durch gezielte Industriespionage, externe Hacking-Angriffe oder schlichtweg durch menschliches Versagen, wie etwa das versehentliche Versenden einer E-Mail mit einem unverschlüsselten Excel-Anhang an den falschen externen Empfänger.

Zur Durchsetzung der Vertraulichkeit auf technischer Ebene bedienen sich Organisationen moderner IAM-Systeme (Identity and Access Management), starker Authentifizierungsverfahren (Multi-Faktor-Authentifizierung) und der Kryptografie (Verschlüsselung von Festplatten, Datenbanken und Netzwerkverbindungen).

4.2. Integrität, Nachvollziehbarkeit und gerichtliche Beweiskraft

Während die Vertraulichkeit sich mit der Frage beschäftigt, *wer* die Daten sehen darf, adressiert die Integrität (Integrity) die Frage, *wie* die Daten beschaffen sind. Der Leitsatz lautet: **"Daten müssen stets korrekt, vollständig und vor unautorisierten heimlichen Änderungen streng geschützt sein."** Die Integrität betrifft ironischerweise alle Kategorien gleichermaßen – auch *Öffentliche-Daten* müssen integer sein, da eine unbemerkt manipulierte Pressemitteilung auf der Webseite zu massiven Börsenturbulenzen führen kann.

Wenn die Integrität von Daten in einem Unternehmen nicht absolut gewährleistet ist, verlieren diese Informationen ihren gesamten Wert, da Managemententscheidungen plötzlich auf der Grundlage von falschen Tatsachen getroffen werden. Um die Integrität nicht nur systemisch sicherzustellen, sondern auch in der Retrospektive belegen zu können, treten zwei weitere unverzichtbare und eng verwandte Konzepte in Kraft:

- **Nachvollziehbarkeit (Audit Trails):** "Jede einzelne Änderung an hochkritischen Daten muss durch ein Protokoll klar beweisbar bleiben." Solche Protokolle (Audit Logs) erfassen minutengenau, welcher spezifische Benutzer zu welchem exakten Zeitpunkt (Timestamp) welche Daten gelesen, neu erstellt, modifiziert oder gelöscht hat. Ohne eine solche granulare Nachvollziehbarkeit lassen sich betrügerische Handlungen (Fraud) im Nachhinein schlicht nicht aufklären, und ein Integritätsverlust bleibt unentdeckt.
- **Beweiskraft:** "Unveränderbare Archive garantieren, dass die gespeicherten Dokumente vor Gericht als gültige Beweismittel gelten." Hierbei kommt in der Enterprise-IT oftmals die sogenannte WORM-Technologie (Write Once, Read Many) zum Einsatz. Ein digitales Dokument (z.B. ein unterzeichneter Leasingvertrag) wird auf einem Storage-System so abgelegt, dass es auf physikalischer oder hardwarenaher Softwareebene nachträglich nicht mehr verändert oder vorzeitig gelöscht werden kann.

4.3. Verfügbarkeit: Der ständige und verlässliche Zugriff

Das dritte und oft von reinen Sicherheitsexperten massiv unterschätzte Kriterium der Triade ist die Verfügbarkeit (Availability). Die klare Vorgabe lautet: **"Geschäftskritische Applikationen und Daten müssen jederzeit für die berechtigten Anwender reibungslos abrufbar bleiben."** Die elaboriertesten, sichersten und am stärksten verschlüsselten Datensätze sind für ein Unternehmen vollkommen nutzlos, wenn die autorisierten Personen sie nicht genau in jenem Moment abrufen können, in dem der Geschäftsprozess sie benötigt. Die Gewährleistung der Verfügbarkeit schützt vor Serviceunterbrechungen, die durch eine Vielzahl von Faktoren ausgelöst werden können: Cyberangriffe (insbesondere Distributed Denial of Service - DDoS, oder Ransomware-Verschlüsselungen), Naturkatastrophen (Brand, Überschwemmung, kompletter Stromausfall), Hardwareversagen (defekte Storage-Arrays) oder durch schlichtweg falsch konfigurierte Software-Updates (wie man es bei globalen Ausfällen grosser Cloud-Anbieter immer wieder sieht).

5. System-Kritikalität und Business Continuity Management (BCM)

Um die *Verfügbarkeit* in der Praxis eines Grossunternehmens strukturiert zu garantieren, reicht es nicht aus, blindlings Server zu spiegeln. Grosse Unternehmen betreiben oftmals hunderte oder gar tausende von Applikationen. Hier kommt das Business Continuity Management (BCM) ins Spiel. Es geht bei dieser Disziplin darum, im Vorfeld (in Friedenszeiten) exakt zu definieren, welche Systeme bei einem katastrophalen Gesamtausfall (Disaster) zuerst gerettet und hochgefahren werden müssen und wie viel potenzieller Datenverlust betriebswirtschaftlich noch tolerierbar ist.

5.1. Kritikalitätsanalyse: Die Trennung in Kern- und Supportsysteme

Bevor technische Wiederherstellungspläne in der IT verfasst werden, muss evaluiert werden, wie wichtig eine Applikation eigentlich für die Wertschöpfung ist.

- **Kritikalitätsanalyse: "Jedes System wird bewertet, wie wichtig es für die Aufrechterhaltung des Geschäftsbetriebs ist."** Diese strukturierte Analyse (im BCM oft als Business Impact Analysis, BIA, bezeichnet) deckt schonungslos auf, welche Prozesse das absolute Herzstück der Firma bilden und welche lediglich unterstützenden Charakter haben. Auf Basis dieser Analyse werden die IT-Systeme hart priorisiert:
 - **Kernsysteme: "ERP-Systeme oder Kassensysteme besitzen höchste Priorität, da ihr Ausfall sofortige massive Umsatzeinbussen verursacht."** Wenn in einer grossen Schweizer Detailhandelskette (z. B. Migros oder Coop) an einem Samstagmorgen die Kassensysteme (Point of Sale, POS) in den Filialen ausfallen, stauen sich die Kunden an den Kassen, verderbliche Waren können nicht abverkauft werden, und der direkte finanzielle sowie der reputationsbezogene Schaden steigt mit jeder Minute in schmerzhaft hohe Höhen. Solche Systeme benötigen Geo-Redundanz und teure Hochverfügbarkeits-Cluster (High Availability).
 - **Supportsysteme: "Interne Werkzeuge wie das Intranet sind wichtig, tolerieren aber einen kurzzeitigen ungeplanten Ausfall."** Wenn das Firmen-Wiki oder die Raumordnungssoftware für drei Stunden nicht erreichbar ist, arbeiten die Mitarbeitenden in den Büros zwar etwas weniger effizient und sind genervt, aber das Unternehmen verdient an der Front weiterhin Geld und die Endkunden bemerken von der Störung absolut nichts.

5.2. Wiederanlaufparameter: RTO und RPO als Zeitachsen

Für jedes identifizierte System (und hier ganz besonders für die Kernsysteme) müssen zwingend zwei zeitliche Parameter für den Notfall mit dem Business ausgehandelt und definiert werden:

- **RTO-Definition (Recovery Time Objective): "Die Recovery-Time-Objective bestimmt die**

maximal akzeptable Dauer bis zur vollständigen erfolgreichen Systemwiederherstellung."

Einfach ausgedrückt beantwortet die RTO die Frage: *Wie lange darf das IT-System nach einem Crash maximal "tot" sein, bevor der finanzielle Schaden für das Unternehmen existenzbedrohend wird?* Für ein Kernsystem wie das erwähnte Kassensystem im Supermarkt liegt die RTO vielleicht bei aggressiven 15 Minuten. Für ein Supportsystem wie das Intranet liegt die RTO eventuell bei entspannten 48 Stunden.

- **RPO-Definition (Recovery Point Objective): "Die Recovery-Point-Objective definiert den maximal tolerierbaren Datenverlust im Falle eines schwerwiegenden technischen Systemausfalls."** Einfach ausgedrückt beantwortet die RPO die Frage: *Wie viel gearbeitete Zeit (in Minuten, Stunden oder Tagen) darf durch das Einspielen des allerletzten Backups maximal unwiederbringlich verloren gehen?* Wenn die RPO für eine Kern-Datenbank einer Bank bei "0 Minuten" liegt (da absolut kein einziger Transaktionsverlust toleriert werden darf), müssen die Serverdaten permanent und synchron über Glasfaser an einen zweiten Standort gespiegelt werden.

5.3. Backup-Strategien und technisches Speichermanagement (Storage Tiering)

Die Vorgaben zu RTO und RPO definieren das organisatorische "Was", aber das technische "Wie" wird durch die physischen und wirtschaftlichen Eigenschaften der Storage-Infrastruktur bestimmt:

- **Datenvolumen: "Die aktuelle Menge an Informationen beeinflusst die Wahl der richtigen passenden Backup-Technologie massgeblich."** Ein kleines Büro mit wenigen Gigabyte kann auf ein NAS sichern. Ein Spital mit Terabytes an hochauflösenden MRT-Bildern benötigt komplexe Enterprise-Storage-Lösungen (SAN).
- **Wachstumsprognose: "Speichersysteme müssen skalierbar sein, um die zukünftig steigenden anfallenden Datenmengen problemlos zu bewältigen."** Daten wachsen exponentiell. Eine Storage-Lösung muss ("Hot-Plug") erweitert werden können.
- **Änderungsrate (Change Rate): "Häufig geänderte Daten erfordern viel kürzere Backup-Intervalle als rein statische unveränderliche historische Archivdaten."** Die Transaktionsdatenbank eines Webshops ändert sich sekundlich und benötigt Continuous Data Protection (CDP). Ein statisches Archiv aus dem Jahr 2015 benötigt nur ein sauberes Full-Backup.
- **Netzwerkbandbreite: "Die Datenübertragung ins Backup-Center darf den regulären produktiven Geschäftsbetrieb niemals negativ stark beeinträchtigen."** Backups massiver Datenmengen während der Bürozeiten stören den Betrieb. Daher nutzt man dedizierte Backup-Netzwerke oder strikte "Backup-Fenster" in der Nacht.
- **Speicherkosten (Information Lifecycle Management): "Teurer Hochleistungsspeicher wird nur für hochkritische Systeme mit sehr strengen SLA-Vorgaben aktiv eingesetzt."** Daten, die als *Geheim* mit harter RTO klassifiziert sind, liegen auf teuren NVMe-SSDs. Ältere *Interne-Daten* werden durch automatisiertes Storage-Tiering auf kostengünstige,

langsamere SATA-Festplatten oder Magnetbänder (Tape) ausgelagert.

6. Compliance, gesetzliche Vorgaben und der Datenlebenszyklus

Neben den rein technischen und betriebswirtschaftlichen Aspekten der Informationssicherheit (Schutzbedarf, CIA, RTO/RPO) wird die Datenklassifizierung heutzutage massgeblich von strikten rechtlichen Rahmenbedingungen diktiert. Daten können und dürfen nicht einfach nach Belieben auf Servern gespeichert und irgendwann wieder gelöscht werden. Die rechtliche Disziplin der **Compliance** (Regelkonformität) ist zu einem Haupttreiber für IT-Budgets geworden.

6.1. Gesetzeskonformität und lange Aufbewahrungsfristen

- **Gesetzeskonformität:** "Unternehmen müssen zwingend alle rechtlichen Vorgaben bei der sicheren Speicherung von Daten einhalten." Die moderne IT-Abteilung operiert längst nicht mehr in einem rechtsfreien Raum, in dem nur technische Parameter zählen. Harte Gesetze wie das Schweizer Obligationenrecht (OR), das revidierte Datenschutzgesetz (revDSG) oder branchenspezifische, hochkomplexe Vorgaben der Eidgenössischen Finanzmarktaufsicht (FINMA) bilden die unumstösslichen Leitplanken jeder IT-Architektur. Werden diese juristischen Vorgaben vom Unternehmen grob fahrlässig ignoriert, drohen dem Management (Verwaltungsrat und Geschäftsleitung) persönliche Haftungsklagen und der Unternehmung empfindliche Strafen.
- **Aufbewahrungsfristen:** "Finanzdaten und geschäftliche E-Mails müssen in der Schweiz für zehn Jahre archiviert werden." Das Gesetz (spezifisch Art. 958f des Schweizerischen Obligationenrechts) schreibt unmissverständlich vor, dass Geschäftsbücher, Buchungsbelege sowie der Geschäftsbericht und der Revisionsbericht während zehn Jahren aufbewahrt werden müssen. Dies stellt eine enorme konzeptionelle Herausforderung an die IT dar: Die Speichermedien und Dateiformate müssen so vorausschauend gewählt werden, dass sie auch nach einem vollen Jahrzehnt noch problemlos lesbar sind (Vermeidung von technischer Software- und Hardware-Obsoleszenz).

6.2. Das Ende des Lebenszyklus: Sichere und unwiederbringliche Vernichtung

Viele Unternehmen konzentrieren sich in ihren Investitionen und Prozessen sehr stark auf das Ansammeln und Speichern von Daten (Big Data), vernachlässigen aber am Ende des Datenlebenszyklus das fachgerechte und sichere Entfernen der Informationen. Ein endlos anwachsender Datenberg ("Data Hoarding") ist jedoch ein massives Haftungs- und Sicherheitsrisiko.

- **Löschkonzepte:** "Nach Ablauf der Frist müssen bestimmte Informationen nachweislich

und unwiederbringlich sicher vernichtet werden." Einerseits dürfen gewisse Daten nach Ablauf der gesetzlichen Pflicht (z.B. der 10 Jahre) entsorgt werden, um Speicherplatz und Risiken zu minimieren. Andererseits *müssen* gewisse Daten zwingend gelöscht werden. Das Schweizer Datenschutzgesetz besagt klar, dass Personendaten vernichtet oder vollständig anonymisiert werden müssen, sobald sie für den ursprünglichen Zweck der Bearbeitung nicht mehr erforderlich sind.

Ein formalisiertes und dokumentiertes Löschkonzept ist daher für jedes Unternehmen essenziell. Das bloße Verschieben in den "Papierkorb" des Betriebssystems oder das schnelle Formatieren einer Festplatte ist keine Löschung im Sinne der IT-Sicherheit. IT-Systeme müssen Daten durch mehrfaches, algorithmisches Überschreiben kryptografisch sicher vernichten (sogenanntes Data Wiping). Wenn Hardware ausgemustert wird, müssen die Datenträger physikalisch in einem industriellen Schredder in kleine Metallpartikel zerkleinert werden (Hardware-Shredding), um Datendiebstahl absolut sicher zu verhindern.

7. Governance und Implementierung im betrieblichen Alltag

Eine saubere Kategorisierung auf dem Papier (Kapitel 2) und eine durchdachte Backup-Architektur (Kapitel 5) sind essenziell, bilden jedoch nur die Basis. Damit Informationssicherheit in der Praxis tatsächlich gelebt wird und die juristischen Compliance-Ziele (Kapitel 6) erreicht werden, bedarf es einer strengen organisatorischen Einbettung – der sogenannten IT-Governance. Die folgenden fünf Mechanismen stellen sicher, dass die Datenklassifizierung nicht nur Theorie bleibt, sondern operativ durchgesetzt wird.

7.1. Richtlinien: Die rechtliche Verankerung im Betrieb

- **"Die Geschäftsleitung erlässt verbindliche Weisungen für den korrekten Umgang mit sensiblen klassifizierten Unternehmensdaten."**

Informationssicherheit ist primär keine IT-Aufgabe, sondern ein Führungsthema (Management Commitment). Die Klassifizierung von Daten erfordert ein unternehmensweites Regelwerk, das als "Information Security Policy" (Informationssicherheitsrichtlinie) bezeichnet wird. Diese Richtlinie muss vom CEO beziehungsweise der Geschäftsleitung unterschrieben und in Kraft gesetzt werden. Sie regelt unmissverständlich, dass das Klassifizierungssystem (von Öffentlich bis Geheim) für alle Mitarbeitenden, Praktikanten und externen Dienstleister absolut bindend ist. Ohne diesen klaren "Tone from the Top" verkommt die Datenklassifizierung zu einer unverbindlichen Empfehlung, an die sich im stressigen Arbeitsalltag niemand hält.

7.2. Zugriffsmanagement: Das Need-to-Know-Prinzip in der Technik

- **"Berechtigungen werden strikt anhand der Datenklasse sowie der jeweiligen benötigten**

Mitarbeiterrolle technisch vergeben."

Die ausgegebenen Richtlinien müssen anschliessend in technische Systeme überführt werden. Dies geschieht durch ein Identitäts- und Zugriffsmanagement (IAM), das klassischerweise auf dem Prinzip der rollenbasierten Zugriffskontrolle (Role-Based Access Control, RBAC) beruht. Einem Mitarbeiter werden Zugriffsrechte nicht mehr individuell und willkürlich gewährt, sondern ausschliesslich basierend auf seiner Funktion (z.B. "Junior Accountant" oder "HR Manager").

Ein IT-System prüft dann zwei Dinge: Welche Rolle hat der Benutzer? Und welche Klasse hat das Dokument? Eine Excel-Tabelle mit der Klasse *Vertrauliche-Daten*, die Gehaltsboni enthält, kann systemseitig nur von der Rolle "HR Management" geöffnet werden. Der Versuch eines Mitarbeiters aus dem Marketing, diese Datei auf dem Server auch nur anzuklicken, wird technisch rigoros blockiert.

7.3. Verschlüsselungspflicht: Der Schutz am Endpunkt

- **"Streng vertrauliche Informationen müssen auf mobilen Geräten zwingend immer sehr stark verschlüsselt sein."**

Mit der Verbreitung von Home-Office und mobilen Arbeitsgeräten (Laptops, Tablets, Smartphones) verlässt die Unternehmensware "Datum" zunehmend die geschützten Grenzen des firmeneigenen Netzwerks (Perimeter). Wenn ein Sales-Manager auf seinem Notebook *Geheime-Daten* oder Kundendaten (Personendaten) mitführt, greift eine zwingende technische Policy: Die Festplatte des Geräts muss komplett verschlüsselt sein (Full Disk Encryption, z.B. via Microsoft BitLocker oder Apple FileVault).

Der Grund dafür ist einfach: Vergisst der Mitarbeiter sein Notebook in einem Zug der SBB, handelt es sich bei einem voll verschlüsselten Gerät lediglich um einen ärgerlichen Hardware- und finanziellen Verlust. Wäre das Gerät jedoch unverschlüsselt, läge ein katastrophaler, meldepflichtiger Datenschutzvorfall (Data Breach) vor, da jeder Finder die Festplatte ausbauen und die Firmendaten sofort frei auslesen könnte.

7.4. Cloud-Nutzung: Wo dürfen die Daten lagern?

- **"Die Klassifizierung bestimmt, welche Daten in eine öffentliche Cloud sicher ausgelagert werden dürfen."**

Der Trend zum Outsourcing von IT-Dienstleistungen zwingt Unternehmen dazu, ihre Cloud-Strategie eng an die Datenklassifizierung zu koppeln. Nicht jede Information darf auf Servern in den USA oder Asien gespeichert werden. Die Klassifizierungsmatrix gibt den Fachabteilungen den Leitfaden vor:

- *Öffentliche-Daten* (z.B. Marketing-Bilder) dürfen problemlos in kostengünstigen, globalen Public-Cloud-Speichern (wie Amazon AWS S3 oder Azure) abgelegt werden.
- Für *Personendaten* oder *Geheime-Daten* (z.B. Forschungsdaten, EPDs) diktiert die Policy häufig, dass diese Daten entweder ausschliesslich in "On-Premise"-Rechenzentren (im eigenen Keller) oder in streng zertifizierten "Sovereign Clouds" verbleiben müssen, deren Rechenzentren sich nachweislich und physisch auf

Schweizer Staatsgebiet befinden (um dem US-CLOUD Act zu entgehen und Schweizer Recht zu garantieren).

7.5. Sanktionen: Die Konsequenz bei Regelverstössen

- **"Die vorsätzliche Missachtung der Klassifizierungsregeln führt zu entsprechenden personellen und rechtlichen strengen Konsequenzen."**

Das beste ISMS ist nutzlos, wenn Verstösse dagegen nicht sanktioniert werden. Wenn in den Richtlinien steht, dass *Interne-Daten* nicht über private Kanäle wie WhatsApp geteilt werden dürfen, und ein Mitarbeiter dies dennoch tut, muss das Unternehmen handeln. Je nach Schwere des Verstosses (Fahrlässigkeit versus böser Vorsatz) und der Kritikalität der betroffenen Daten (Handelt es sich um den Kantinenplan oder um Kundendossiers?) müssen gestaffelte Konsequenzen definiert sein. Diese reichen im Rahmen des Schweizer Arbeitsrechts von einer formellen mündlichen Verwarnung über den sofortigen, fristlosen Entzug der IT-Privilegien bis hin zur Kündigung. Bei vorsätzlichem Diebstahl von *Geheimen-Daten* (Wirtschaftsspionage) leiten Firmen zudem zivil- und strafrechtliche Schritte gegen den Täter ein. Diese Sanktionsmöglichkeit entfaltet eine präventive, abschreckende Wirkung im gesamten Betrieb.

8. Fazit

Die strukturierte und durchdachte Datenklassifizierung in klar abgegrenzte Kategorien (von Öffentlichen Daten bis hin zu streng Geheimen Daten und Personendaten) ist in der heutigen Geschäftswelt keinesfalls eine rein bürokratische Übung. Sie ist vielmehr das unverzichtbare, strategische Steuerungsinstrument, um finanzielle und personelle Sicherheitsressourcen zielgerichtet, wirtschaftlich effizient und vor allem gesetzeskonform einzusetzen.

Erst wenn ein Unternehmen durch eine fundierte Schutzbedarfsfeststellung und eine darauffolgende Kritikalitätsanalyse (BIA) verstanden hat, welche seiner IT-Systeme existenzkritisch sind, kann es seine RTO- und RPO-Ziele für den Notfall seriös planen und mit der passenden Backup- und Speicher-Strategie unterlegen. Der Schutz der Vertraulichkeit durch striktes rollenbasiertes Zugriffsmanagement und zwingende Verschlüsselung auf mobilen Geräten stellt sicher, dass wertvolle Geschäftsgeheimnisse intern bleiben und das strenge Schweizer Datenschutzgesetz jederzeit gewahrt wird. Die kompromisslose Wahrung der Datenintegrität garantiert die juristische Beweiskraft.

Umrahmt wird dieses technische Setup in der Schweiz durch regulatorische Compliance – von zehnjährigen Aufbewahrungsfristen bis hin zu rigiden Löschkonzepten. Doch all dies muss durch eine starke Governance (Richtlinien, Cloud-Vorgaben und Sanktionen) in den Köpfen der Mitarbeitenden verankert werden. Zusammen bilden diese Kriterien, Konzepte und Governance-Regeln ein robustes, ganzheitliches Framework. Dieses ermöglicht es Schweizer Organisationen, in einer von rasanten technologischen Veränderungen geprägten Welt nicht nur zu überleben, sondern vertrauenswürdig, rechtssicher und hochgradig agil am Markt zu

agieren.

Quellenverzeichnis

- **BSI (Bundesamt für Sicherheit in der Informationstechnik) (2023):** *IT-Grundschutz-Kompendium*. Bonn: BSI. (Zentrales Werk für die Methodik der Schutzbedarfsfeststellung, RTO/RPO Definitionen und Basisabsicherung).
- **ISO/IEC 27001:2022 (2022):** *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Genf: International Organization for Standardization (ISO). (Der anerkannte globale Standard für den Aufbau eines ISMS, Governance-Richtlinien und die Prinzipien der Datenklassifizierung).
- **ISO 22301:2019 (2019):** *Security and resilience — Business continuity management systems — Requirements*. Genf: ISO. (Der globale Standard für Business Continuity Management und Kritikalitätsanalysen).
- **Schweizerisches Obligationenrecht (OR) (Stand 2024):** *Art. 958f (Aufbewahrung der Geschäftsbücher)*. Bern: Schweizerische Eidgenossenschaft. (Die gesetzliche Grundlage der zwingenden zehnjährigen Aufbewahrungsfrist).
- **Schweizerische Eidgenossenschaft (2023):** *Bundesgesetz über den Datenschutz (Datenschutzgesetz, revDSG) vom 25. September 2020 (Stand am 1. September 2023)*. Bern. (Die rechtliche Grundlage für Sanktionen, Cloud-Outsourcing-Bedingungen und den Umgang mit Personendaten in der Schweiz).
- **Eckert, C. (2018):** *IT-Sicherheit: Konzepte - Verfahren - Protokolle* (10. Aufl.). Berlin, Boston: De Gruyter Oldenbourg. (Wissenschaftliches Grundlagenwerk zu den Themen Kryptografie, IAM und den CIA-Schutzzielen).
- **Schmeh, K. (2016):** *Kryptografie: Verfahren, Protokolle, Infrastrukturen* (6. Aufl.). Heidelberg: dpunkt.verlag. (Detaillierte akademische Erklärungen zu Verschlüsselungstechniken für mobile Endgeräte).